Lab 5: Static Code Analysis

Name	Armaan
SRN	PES2UG24CS083

Music Catalog and Playlist Manager (`music_catalog.py`)

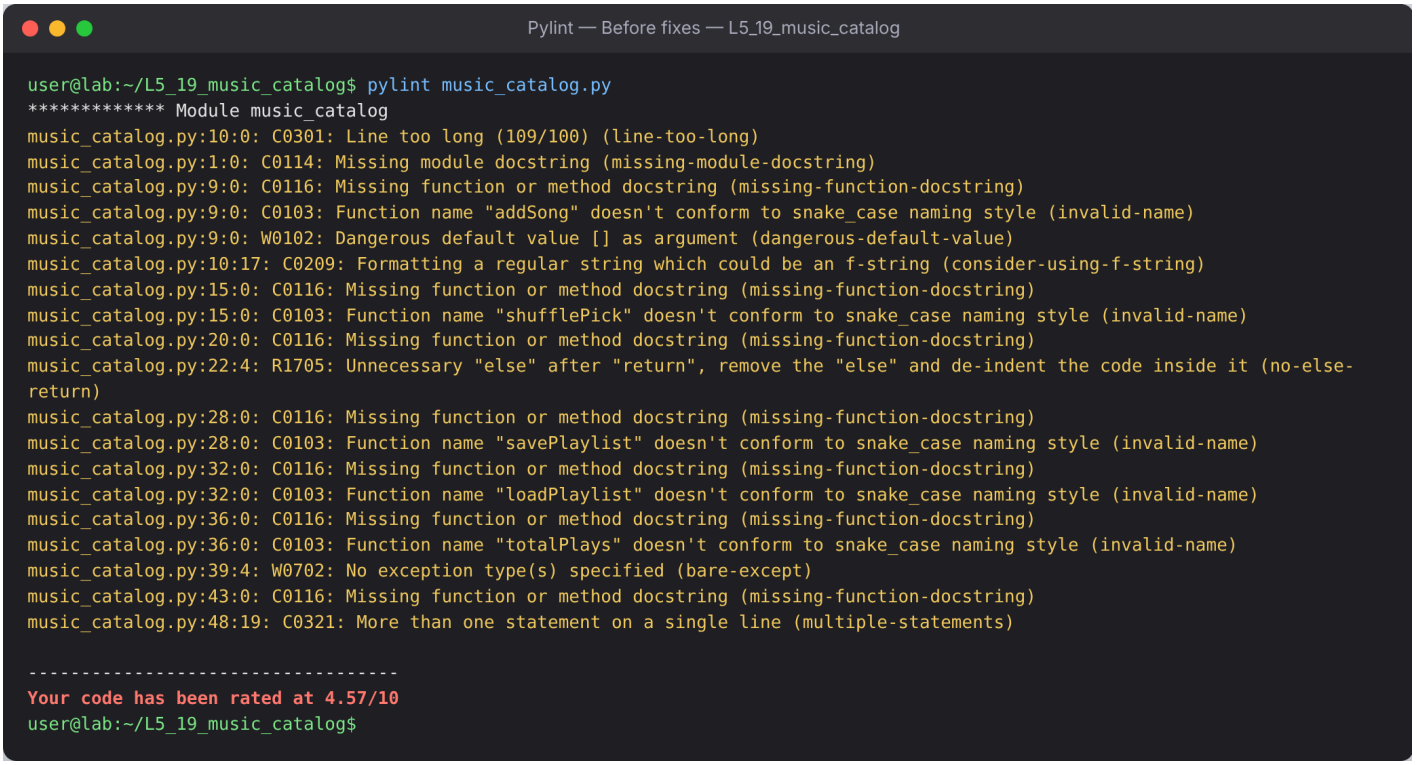
Output of Pylint, Bandit and Flake8, before and after the fixes.

Tool	Before	After
Pylint	4.57/10 (19 messages)	10.00/10 (0 messages)
Bandit	4 issues (2 Medium, 2 Low)	0 issues
Flake8	7 issues	0 issues (no output)

Flake8 prints nothing when the code is clean, so the "after" screenshot shows only the command and the next prompt.

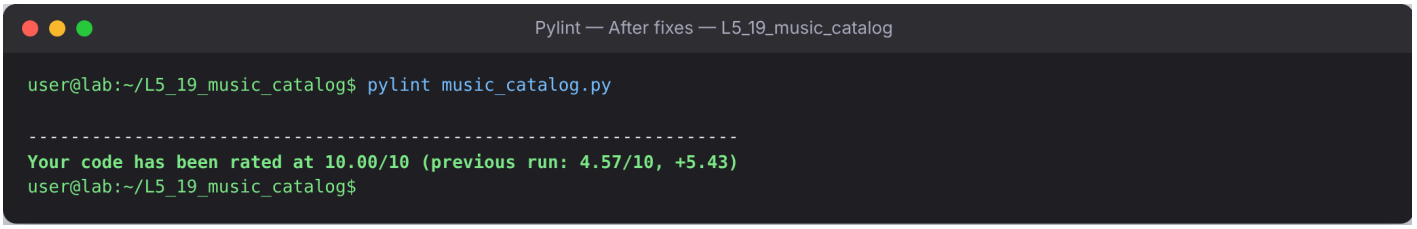
Armaan · PES2UG24CS083

Pylint — Before fixes



Armaan · PES2UG24CS083

Pylint — After fixes



Armaan · PES2UG24CS083

Bandit — Before fixes

Bandit — Before fixes — L5_19_music_catalog

```
user@lab:~/L5_19_music_catalog$ bandit -r music_catalog.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.16
Run started:2026-10-14 16:15:04.154942+00:00

Test results:
>> Issue: [B403:blacklist] Consider possible security implications associated with pickle module.
   Severity: Low   Confidence: High
   CWE: CWE-502 (https://cwe.mitre.org/data/definitions/502.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b403-import-pickle
   Location: ./music_catalog.py:1:0
1       import pickle
2       import random
3       import sqlite3

--------------------------------------------------
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query construction.
   Severity: Medium   Confidence: Medium
   CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html
   Location: ./music_catalog.py:10:17
9       def addSong(title, artist, plays=0, playlist=[]):
10          conn.execute("INSERT INTO songs (title, artist, plays) VALUES ('%s', '%s', %d)" % (title, artist, plays))
11          playlist.append(title)

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: ./music_catalog.py:17:11
16          ids = [r[0] for r in conn.execute("SELECT id FROM songs")]
17          return random.choice(ids)
18

--------------------------------------------------
>> Issue: [B301:blacklist] Pickle and modules that wrap it can be unsafe when used to deserialize untrusted data, possible
security issue.
   Severity: Medium   Confidence: High
   CWE: CWE-502 (https://cwe.mitre.org/data/definitions/502.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b301-pickle
   Location: ./music_catalog.py:33:11
32      def loadPlaylist(blob):
33          return pickle.loads(blob)
34

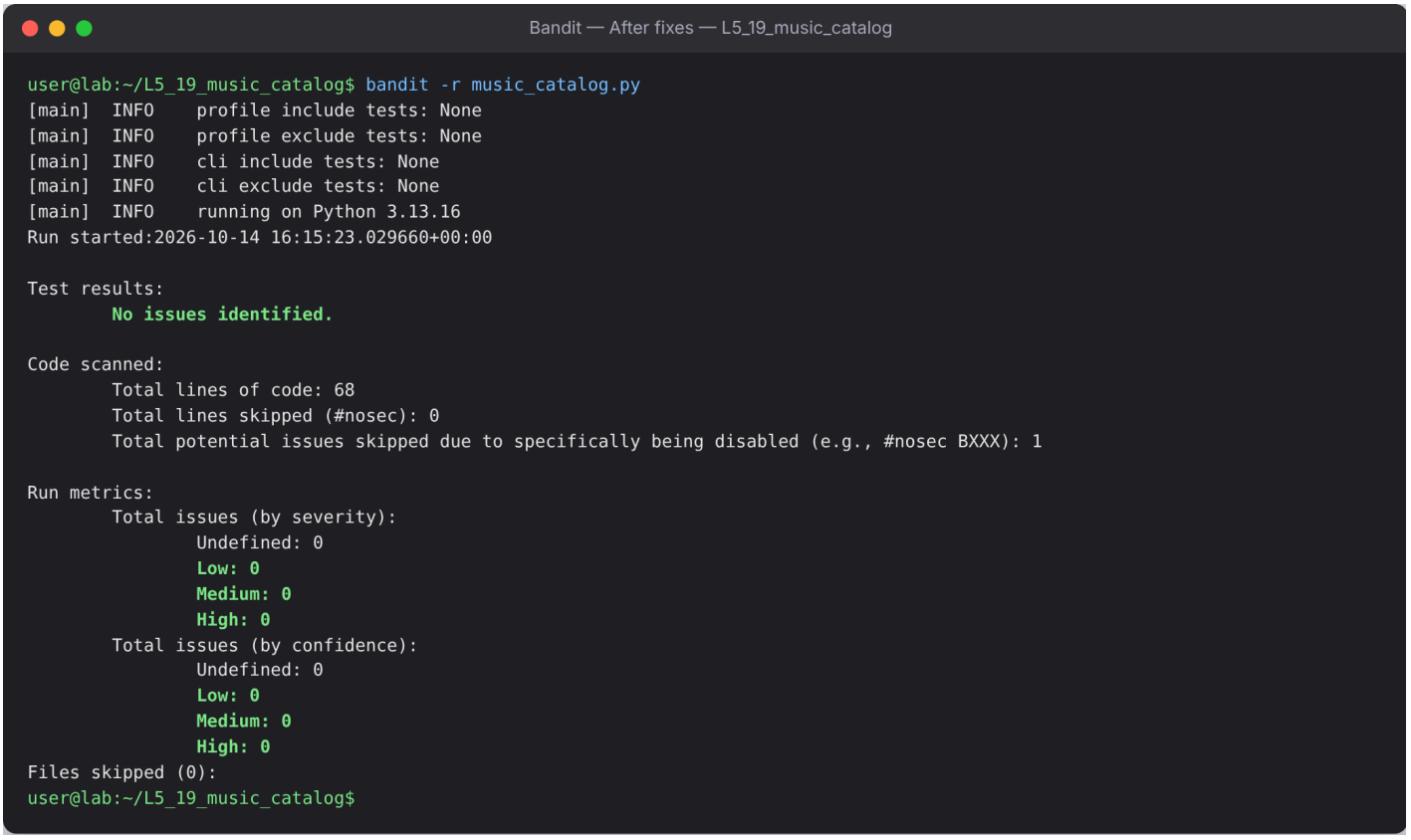
--------------------------------------------------

Code scanned:
        Total lines of code: 35
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 2
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 1
                High: 3
Files skipped (0):
user@lab:~/L5_19_music_catalog$
```

Armaan · PES2UG24CS083

Bandit — After fixes



Armaan · PES2UG24CS083

Flake8 — Before fixes

Flake8 — Before fixes — L5_19_music_catalog

```
user@lab:~/L5_19_music_catalog$ flake8 music_catalog.py
music_catalog.py:6:80: E501 line too long (99 > 79 characters)
music_catalog.py:10:80: E501 line too long (109 > 79 characters)
music_catalog.py:21:80: E501 line too long (86 > 79 characters)
music_catalog.py:39:5: E722 do not use bare 'except'
music_catalog.py:47:5: E741 ambiguous variable name 'l'
music_catalog.py:48:18: E701 multiple statements on one line (colon)
music_catalog.py:49:80: E501 line too long (83 > 79 characters)
user@lab:~/L5_19_music_catalog$
```

Armaan · PES2UG24CS083

Flake8 — After fixes

Flake8 — After fixes — L5_19_music_catalog

```
user@lab:~/L5_19_music_catalog$ flake8 music_catalog.py
user@lab:~/L5_19_music_catalog$
```